

BUILD WEEK 3 // ESERCIZIO 5

Report di Analisi Minacce ANY.RUN

Analisi sandbox di campioni malware e phishing
con classificazione, valutazione e remediation

ANY.RUN | Vidar Stealer | Phishing | Sandbox Analysis

ESERCITAZIONE	Esercizio 5 -- Analisi Minacce ANY.RUN
AMBIENTE	ANY.RUN -- Sandbox interattiva
CLASSIFICAZIONE	Uso Interno / Cliente
AUTORE	_____
DATA	23 giugno 2026



00

Indice

L'indice seguente anticipa la struttura del report: dall'analisi del campione malware Vidar Stealer, alla valutazione del link di phishing via ConvertKit/Instagram, fino al riepilogo esecutivo.

01 Campione 1 -- Vidar Stealer (vidar.exe)

- 1.1 Informazioni Generali
- 1.2 Cos'è Vidar Stealer?
- 1.3 Cosa ruba concretamente?
- 1.4 Come funziona tecnicamente?
- 1.5 Vettori di infezione
- 1.6 Valutazione
- 1.7 Remediation

02 Campione 2 -- Phishing via ConvertKit / Instagram

- 2.1 Informazioni Generali
- 2.2 Perché ANY.RUN non ha rilevato minacce?
- 2.3 Analisi della catena di attacco
- 2.4 Possibili scenari
- 2.5 Valutazione
- 2.6 Remediation

03 Riepilogo Esecutivo

- 3.1 Tabella riepilogativa
- 3.2 Lezione chiave

01

Campione 1 -- Vidar Stealer (vidar.exe)

• 1.1 Informazioni Generali

Campo	Valore
Nome file	66bddfcb52736_vidar.exe
MD5	FEDB687ED23F77925B35623027F799BB
Tipo	Eseguibile Windows (PE32)
Verdetto ANY.RUN	Malicious activity
Famiglia malware	Vidar Stealer
Tag	stealer, vidar, telegram, arch-exec
Link sandbox	https://app.any.run/tasks/371957e1-d960-4b8a-8c68-241ff918517d/

• 1.2 Cos'e' Vidar Stealer?

Vidar Stealer e' un malware di tipo **info-stealer**, progettato cioe' per rubare dati sensibili dal sistema infetto, scritto originariamente in C++ e attivo dal 2018. Opera con un modello **Malware-as-a-Service (MaaS)**: chiunque voglia utilizzarlo puo' acquistare una licenza sul dark web (tra i 130 e i 750 dollari) e ottenere accesso a un pannello di controllo personalizzabile per configurare esattamente quali dati rubare dalle vittime.

Si ritiene che Vidar abbia origini russe, in quanto la lingua principale utilizzata nei canali di supporto (Telegram) e' il russo.

• 1.3 Cosa ruba concretamente?

Vidar e' in grado di sottrarre:

- **Credenziali dei browser** (Chrome, Firefox, Edge, Tor) -- username, password, cookie, cronologia, dati di autocompilazione
- **Dati bancari e carte di credito** salvati nei browser
- **Wallet di criptovalute** (Bitcoin, Ethereum, Litecoin, Zcash, DashCore)
- **Screenshot del desktop** al momento dell'infezione
- **Messaggi privati** da applicazioni di messaggistica
- **File sensibili** nelle directory utente (documenti, testi, ecc.)

• 1.4 Come funziona tecnicamente?

1. Esecuzione: il file viene avviato sul sistema della vittima (tramite email, installer contraffatto, malvertising, ecc.)

2. Anti-analisi: il malware effettua controlli per rilevare ambienti di analisi (sandbox, debugger, AV) prima di procedere

3. Recupero C2: contatta server di comando e controllo i cui indirizzi IP sono pubblicati su profili social pubblici (Telegram, Steam), permettendo agli attaccanti di cambiare server semplicemente aggiornando un profilo, senza destare sospetti nei firewall

4. Raccolta dati: estrae tutte le informazioni target e le organizza in una cartella nascosta sotto ProgramData

5. Esfiltrazione: comprime tutto in un archivio ZIP e lo invia al C2

6. Autodistruzione: cancella tutti i file raccolti e si elimina dal sistema, rendendo molto difficile l'analisi forense successiva

• 1.5 Vettori di infezione

- Campagne di **spam email** con allegati malevoli (fatture false, notifiche di spedizione, rinnovi abbonamento)
- **Annunci Google Search** malevoli che imitano pagine di download di software legittimi
- **Installer contraffatti** di software noti (Adobe Photoshop, Microsoft Teams, ecc.)
- **Fake CAPTCHA** su siti WordPress compromessi

• 1.6 Valutazione

[OK] VERO POSITIVO -- Malware confermato

Il campione e' classificato con certezza come Vidar Stealer. Il nome del file (vidar.exe), l'MD5 e il comportamento osservato in sandbox corrispondono a campioni noti. Non ci sono elementi che suggeriscano un falso positivo.

• 1.7 Remediation

Azione	Priorita'	Motivazione
Isolare immediatamente il sistema dalla rete	[CRITICA]	Bloccare eventuale esfiltrazione dati ancora in corso
Mettere in quarantena il file	[CRITICA]	Impedire ulteriore esecuzione
Eliminare il file	[CRITICA]	Nessun utilizzo legittimo; rimuovere definitivamente
Blacklist hash MD5	[CRITICA]	Aggiungere FEDB687ED23F77925B35623027F799BB alle regole SIEM/EDR
Cambio di tutte le credenziali	[CRITICA]	Da eseguire da un dispositivo pulito e non compromesso
Indagine forense post-infezione	[ALTA]	Verificare se i dati sono gia' stati esfiltrati e in che intervallo temporale
Blocco domini/IP C2 noti	[ALTA]	Aggiornare le blacklist di rete con gli IoC associati alla famiglia Vidar
Reimaging del sistema	[MEDIA]	Valutare se il sistema e' attendibile dopo l'infezione

[ATTENZIONE] Nota per il cliente/manager

Se questo file e' stato eseguito su una macchina reale (non in ambiente di test), bisogna assumere che **tutte le password salvate nel browser, i dati delle carte di credito e le credenziali aziendali siano potenzialmente compromesse**. E' necessario cambiare immediatamente tutte le password critiche (email, VPN, banking, portali aziendali) operando da un dispositivo pulito.

02

Campione 2 -- Phishing via ConvertKit / Instagram

● 2.1 Informazioni Generali

Campo	Valore
URL analizzato	https://click.convertkit-mail2.com/wvuqovqrwagh50ndddc7hnxdlxxu8/...
Tipo	URL con redirect (link da email)
Verdetto ANY.RUN	No threats detected (fuorviante -- vedi analisi)
Destinazione finale (Base64 decoded)	www.instagram.com/aussienurserecruiter
Classificazione corretta	Phishing -- Vero Positivo
Link sandbox	https://app.any.run/tasks/f1f20828-2222-46fb-a886-09f77581e67b/

● 2.2 Perché ANY.RUN non ha rilevato minacce?

ANY.RUN ha classificato questo campione come "no threats detected" perché, al momento dell'esecuzione in sandbox, il redirect finale puntava a un profilo Instagram apparentemente reale. Tuttavia, il verdetto automatico della sandbox **non è sufficiente** per escludere una minaccia in questo contesto.

● 2.3 Analisi della catena di attacco

Il link segue una struttura tipica delle campagne di **phishing tramite redirect**:

1. **Link iniziale** da `click.convertkit-mail2.com` -- dominio di ConvertKit, piattaforma legittima di email marketing, usata dagli attaccanti per bypassare i filtri antispam
2. **Stringa Base64** nell'URL che offusca la destinazione reale
3. **Redirect finale** verso un profilo Instagram o una pagina che imita un sito affidabile

Il dominio `click.convertkit-mail2.com` è stato documentato ripetutamente in campagne di phishing attive, dove veniva usato per reindirizzare le vittime verso pagine che imitano DocuSign, Microsoft Login, Google Cloud e altre piattaforme, allo scopo di rubare credenziali e codici 2FA.

● 2.4 Possibili scenari

Scenario	Probabilità	Descrizione
Evasione temporale	[ALTA]	La destinazione del redirect cambia nel tempo: benigna durante l'analisi sandbox, malevola quando la vittima reale clicca
Esca per furto credenziali Instagram	[MEDIA]	Il link porta a una pagina che imita il login di Instagram per sottrarre username e password
Email legittima mal classificata	[BASSA]	L'email potrebbe essere una newsletter reale, ma il contesto e il mittente non sono verificati

2.5 Valutazione

[OK] VERO POSITIVO -- Phishing

Nonostante il verdetto "No threats detected" di ANY.RUN, questo campione deve essere classificato come **phishing confermato**. La sandbox non ha rilevato minacce attive perché non esegue codice JavaScript avanzato né segue redirect dinamici condizionali. L'analisi contestuale del dominio e della struttura del link porta a una classificazione di rischio elevato.

Il verdetto automatico della sandbox **non sostituisce l'analisi umana** -- questo caso ne è un esempio lampante.

2.6 Remediation

Azione	Priorita'	Motivazione
Blacklist dell'URL completo	[CRITICA]	Bloccare il link nei filtri email, proxy e firewall
Segnalare a ConvertKit	[ALTA]	L'account mittente potrebbe essere stato compromesso o creato ad hoc
Segnalare a Instagram	[ALTA]	Il profilo potrebbe essere usato come esca o essere falso
Verificare i log proxy/firewall	[ALTA]	Controllare se qualche utente interno ha già cliccato il link
Cambio credenziali (se cliccato)	[CRITICA]	Se un utente ha inserito credenziali, cambiarle immediatamente
Educazione degli utenti	[MEDIA]	Formare il personale a non cliccare link email non attesi, anche se sembrano portare a siti noti come Instagram

[NOTA] Nota per il cliente/manager

Questo link non contiene un virus tradizionale, ma è progettato per **ingannare l'utente** e fargli inserire le proprie credenziali su una pagina falsa. È un attacco di tipo "phishing": tecnicamente invisibile alla maggior parte degli antivirus, ma potenzialmente molto pericoloso. Il consiglio è di non cliccare mai link ricevuti via email senza prima verificare il mittente e, in caso di dubbio, contattare direttamente il servizio citato aprendo il sito manualmente dal browser.

03

Riepilogo Esecutivo

#	Campione	Tipo	Verdetto ANY.RUN	Classificazione corretta	Rischio
1	66bddfcb52736_vidar.exe	Malware eseguibile	Malicious activity	[OK] Vero Positivo -- Malware	[CRITICA] Critico
2	click.convertkit-mail2.com -> Instagram	URL / Link email	No threats detected	[OK] Vero Positivo -- Phishing	[CRITICA] Alto

- **Lezione chiave**

Il secondo campione dimostra un concetto fondamentale nell'analisi delle minacce: **il verdetto automatico di una sandbox non e' sempre sufficiente**. Le tecniche di evasion temporale, i redirect dinamici e l'abuso di piattaforme legittime (ConvertKit, Instagram) sono progettati proprio per ingannare i sistemi automatici. L'analisi contestuale e la valutazione umana rimangono indispensabili per una corretta classificazione delle minacce.

Report generato il 23 giugno 2026 -- Inline Business Consulting S.r.l.